MANAGEMENT OF INFORMATION SECURITY · WEEK 1

LAB 1

Information Asset Inventory & CIA Classification

Identify what an organization must protect, who is responsible for it, and how much each asset matters.

Duration	60–75 minutes	**Format**	Pairs (one submission per pair)
Objectives	Lecture objectives 1 and 4	**Submit**	Completed handout as PDF + answers
Materials	This handout, lecture slides 6–25, internet access	**Weight**	100 points

Student 1	Nazerke	**Student 2**	
Group / section		**Date**	03.10.2026

1. Learning objectives

By the end of this lab you will be able to:

- Identify information assets across the six components of an information system (data, software, hardware, people, procedures, networks).
- Distinguish between the owner, custodian and user of an information asset.
- Rate the confidentiality, integrity and availability (CIA) impact of each asset using a consistent scale and justify the rating.
- Derive a data classification level from CIA ratings using the high-water-mark rule.
- Map controls to cells of the McCumber (CNSS) cube: goal × information state × safeguard.
- Recognize technological obsolescence as a risk by checking vendor support status.

2. Background

You cannot protect what you do not know you have. Every security program begins with an inventory of information assets — the organizational resources that are being protected. An asset can be logical (a customer database, a web application), physical (a laptop, a server, a warehouse badge reader), or human (a key administrator whose knowledge nobody else has).

Roles

Role	Who it is	Responsibility
Owner	A business manager (e.g., Head of Sales)	Decides how valuable the asset is, who may use it and how it is classified. Accountable for it.
Custodian	Usually IT or an operations team	Protects and maintains the asset day to day: backups, patching, access configuration.
User	Anyone authorized to use it	Uses the asset according to policy and reports problems.

CIA impact scale

Rate each characteristic separately by asking: "If this characteristic were lost, how bad would it be for the organization?"

Rating	Confidentiality (C) — if disclosed	Integrity (I) — if altered	Availability (A) — if unavailable
1 — Low	Little or no harm; information is essentially public	Errors are easily noticed and corrected; minor inconvenience	Work continues with minor delay for several days
2 — Moderate	Embarrassment, limited financial or legal harm	Wrong decisions or payments possible; rework needed	Important processes slow or stop within a day
3 — High	Serious legal, financial or safety harm; loss of trust	Fraud, safety risk or major financial loss	Core operations stop within hours; customers affected

Classification (high-water mark)

The overall impact of an asset is the **highest** of its three ratings. Use it to assign a classification label:

Overall impact	Classification	Typical handling
1	Public / Internal	May be shared inside the company; public only if approved
2	Confidential	Need-to-know access, encrypted in transit, no personal devices
3	Restricted	Named individuals only, encrypted at rest and in transit, access logged and reviewed

> **WHY MANAGERS CARE**
>
> Asset owners are business managers, not IT. The CISO and IT can protect an asset, but only the business can say how much it is worth and how much downtime or disclosure it can tolerate. This is exactly the "communities of interest" idea from the lecture.

3. Scenario: Silk Road Logistics LLC

Silk Road Logistics is a fictional freight and warehousing company with 180 employees, a head office in Tashkent and three regional warehouses. Customers book shipments through a web portal and track parcels in a mobile app. The company employs drivers, warehouse staff, a sales team, a finance department and a four-person IT team. There is no dedicated security manager yet — the IT manager "handles security when there is time". The CEO has asked your pair to produce the company's first information asset inventory.

During a walk-through you noted the following candidate assets:

#	Candidate asset	#	Candidate asset
1	Customer database (names, phone numbers, addresses, contracts)	9	Warehouse Wi-Fi network used by handheld scanners
2	Online booking and tracking web portal	10	Payroll spreadsheets kept by the chief accountant
3	Driver mobile app and the phones it runs on	11	The IT manager — the only person who knows the server passwords
4	Accounting software and its server (installed 2016)	12	Procedure for approving supplier bank-account changes

#	Candidate asset	#	Candidate asset
5	Office file server with shared folders	13	Company website (marketing pages and public price list)
6	Staff laptops, several still running Windows 10	14	Nightly backup to a USB drive kept in the server room
7	Internet connection and office router/firewall	15	CCTV recorder for the warehouses
8	Email and calendar service (cloud)	16	Signed customer contracts (paper archive)

4. Tasks

Part A — Build the inventory (15 min)

1. Choose 10 assets from the list above. Your selection must include at least one asset from five of the six information-system components.
2. For each asset, record its component type and the information state(s) in which it matters most: storage, processing or transmission.
3. Name a realistic owner (a business role, not a person's name) and custodian for each asset.
4. Row 1 has been completed as an example — you may keep it as one of your 10.

#	Asset	Component	State(s)	Owner	Custodian
1	Customer database	Data	Storage, processing	Head of Sales	IT team (DB admin)
2	Online booking and tracking web portal	Software	Processing, transmission	Head of Sales	IT team / web administrator
3	Office file server with shared folders	Hardware	Storage, processing	Operations Manager	IT team / system administrator
4	Staff laptops - Windows 10	Hardware	Storage, processing, transmission	Department Heads	IT support team
5	Internet connection and office router/firewall	Networks	Transmission	Operations Manager	IT network administrator
6	Email and calendar service (cloud)	Software	Storage, processing, transmission	HR / Administration Manager	IT team + cloud provider
7	Payroll spreadsheets	Data	Storage, processing	Chief Accountant	Finance team + IT backup support
8	IT manager - only person who knows server passwords	People	Processing	General Manager / CEO	IT Manager; backup administrator needed
9	Procedure for approving supplier bank-account changes	Procedures	Processing	Chief Financial Officer	Finance / Accounts Payable team
10	Nightly backup to a USB drive in the server room	Data	Storage	IT Manager	IT team / backup administrator

Part B — Rate CIA impact and classify (20 min)

1. For each asset from Part A, rate C, I and A from 1 to 3 using the impact scale in Section 2.
2. Compute the overall impact (the highest of the three) and assign the classification.
3. Write one sentence justifying the highest rating. Refer to a concrete consequence (fines, lost orders, safety, fraud).

#	Asset	C	I	A	Overall	Classification	Justification for the highest rating
1	Customer database	3	2	2	3	Restricted	Disclosure of personal data can breach privacy obligations and damage customer trust.
2	Online booking and tracking web portal	2	3	3	3	Restricted	Tampering or a long outage can create false shipment data, stop bookings and cause lost orders.
3	Office file server with shared folders	2	3	3	3	Restricted	Corrupted or unavailable shared files can stop several departments and cause major rework.
4	Staff laptops - Windows 10	2	2	2	2	Confidential	A compromised laptop may expose internal files and interrupt an employee's work, but operations can continue using replacements.
5	Internet connection and office router/firewall	2	3	3	3	Restricted	A four-hour outage can cut staff off from cloud services and customer systems, stopping core work.
6	Email and calendar service (cloud)	3	3	3	3	Restricted	Email may contain contracts, personal data and payment instructions; compromise can enable fraud or expose sensitive information.
7	Payroll spreadsheets	3	3	2	3	Restricted	Unauthorized disclosure exposes salary data, while altered figures can cause incorrect or fraudulent payments.
8	IT manager - server-password knowledge	3	3	3	3	Restricted	If this knowledge is lost, leaked or misused, systems may become inaccessible or privileged credentials may be abused.
9	Supplier bank-account change procedure	2	3	2	3	Restricted	An altered or bypassed approval process can redirect supplier payments to an attacker and cause financial loss.
10	Nightly backup USB drive	3	3	3	3	Restricted	Loss, theft or corruption of the backup can expose copied data and prevent recovery after a major incident.

Part C — Map controls to the McCumber cube (20 min)

Choose the three assets with the highest overall impact. For each, pick the CIA goal you rated highest and the information state where it is most exposed. Then propose one control for each safeguard layer — policy, education and technology. Together the three controls should cover one cell “in depth”.

Asset	Goal	State	Policy control	Education control	Technology control
Customer database	C	Transmission	Customer data may be sent outside the company only through approved encrypted channels.	Train sales staff to use the secure file-share and never personal email for customer data.	TLS on the portal; DLP rule on email; encrypted VPN for administration.
Internet connection and office router/firewall	A	Transmission	Require documented change windows, tested rollback and a business-continuity plan for network outages.	Train help-desk and managers to recognize network incidents and follow the escalation procedure.	Use redundant ISP links and a spare/HA firewall with monitored configuration backups.
Payroll spreadsheets	I	Storage / processing	Payroll changes require role-based access and independent review before payment is released.	Train finance staff to verify changes, detect phishing and report unexpected payroll instructions.	Restrict file permissions, enable version history/backups and MFA on the finance account.

Part D — Lifecycle and obsolescence check (10 min)

Technological obsolescence is one of the twelve threat categories. Pick every hardware or software asset from your inventory (at least three) and look up whether the vendor still supports the version in use. Use only official vendor pages.

Asset / product and version	Vendor end-of-support date	Still supported? (Y/N)	Recommended management action
Staff laptops - Windows 10	14 October 2025	N	Upgrade eligible devices to Windows 11; use ESU only as a temporary bridge; replace incompatible hardware.
Office file server - vendor/model/OS version not stated	Cannot verify from scenario	Unknown	Record server make, model and OS version in the asset inventory, then check the official vendor lifecycle page and plan upgrade/replacement.
Internet router/firewall - vendor/model/firmware not stated	Cannot verify from scenario	Unknown	Identify vendor, model and firmware; check vendor support/EOL status; replace or upgrade unsupported equipment.
Online booking portal - custom/application version not stated	Not applicable / cannot verify	Unknown	Document the application stack and supported versions; establish patching, dependency review and an application lifecycle owner.

Part D evidence note: the scenario gives a precise product/version only for Windows 10. The other selected hardware/software assets do not include vendor, model, firmware or software version, so end-of-support dates cannot be verified without inventing data. Official source used: Microsoft, "Windows 10 support has ended on October 14, 2025."

5. Analysis questions

A1. The Head of Sales should own the customer database because the business owner understands why the data is needed, who should access it, how sensitive it is and how much loss or downtime the business can tolerate. IT should be the custodian that implements controls. If IT "owns" everything, business accountability becomes unclear and technical staff may make classification or risk decisions without enough business context.

A2. The online booking and tracking web portal received Availability = 3. If it is unavailable for four hours on a Monday morning, customers cannot make new bookings or track shipments, staff receive more support calls, orders may be delayed or lost, and the company can suffer SLA problems and loss of trust.

A3. Yes. The public price list alone is not sensitive and individual GPS points may seem low-risk, but together they can reveal which routes are valuable, when vehicles are likely to move and where shipments may be located. Aggregation can therefore create operational intelligence that could support theft, fraud or competitor analysis.

A4. People are information assets because they hold credentials, tacit knowledge, procedures and experience that may not exist anywhere else. Here the IT manager is a single point of failure because only one person knows the server passwords. Reduce the risk with a privileged-access/password vault, documented runbooks and at least one trained backup administrator using controlled access.

A5. Education was the hardest safeguard layer because training must change real behaviour and be specific to each risk; it is not enough to give one generic security presentation. This suggests organizations often find it easier to buy technology or write policies than to maintain continuous, role-based security awareness and good security habits.

6. Deliverables and submission

- All four tables completed (Parts A–D) and answers to Q1–Q5.
- Save as PDF named Lab1_Surname1_Surname2.pdf and upload to the course page before the deadline.
- Cite any web sources used in Part D (vendor name and page title is enough).

Grading rubric

Criterion	Excellent	Adequate	Weak	Points
Part A — Inventory	10 relevant assets, 5+ components, realistic owners and custodians	Mostly complete; some owners are IT or vague	Fewer than 10 assets or components missing	20
Part B — CIA & classification	Consistent ratings, correct high-water mark, concrete justifications	Ratings plausible but justifications generic	Inconsistent ratings or wrong classification rule	25
Part C — McCumber mapping	Three assets; controls clearly fit the cell and all three layers	Controls present but some do not fit the cell	Layers missing or controls unrelated	25
Part D — Lifecycle	Correct dates from vendor sources, sensible actions	Dates present, actions vague	Missing or unsourced	10
Questions Q1–Q5	Clear, uses lecture concepts correctly	Partly correct	Missing or off-topic	15

Criterion	Excellent	Adequate	Weak	Points
Presentation	Neat, complete, correctly named file	Minor issues	Hard to read	5

> **ETHICS REMINDER**
>
> This lab uses a fictional company. If you use your own workplace or university as inspiration, do not record real passwords, IP addresses, personal data or internal documents in your submission.